TEETHTECH CRM MVP · АУДИТ 7–8 ОКТЯБРЯ 2026

Готовность к продакшену и план CI/CD

Проверены MVP-фронт, основной Go-backend, Go-панель SaaS, интеграции PostgreSQL/S3, контейнеры, резервное копирование и процедуры обновления. Исходные Java/Go-проекты не являются предметом этого выпуска.

> **Решение: полноценный запуск с реальными данными пациентов пока не одобрен.**
> Демо и пилот с вымышленными данными можно продолжать. Функциональные проверки проходят, но контейнерные находки, внешний бэкап и настройки реального сервера остаются блокерами.

Это аудит локальной сборки и конфигурации. Сервер лаборатории, публичные DNS/TLS, реальная нагрузка и внешний тест на проникновение не проверялись. Результаты сканеров не являются доказательством эксплуатации каждой найденной уязвимости.

1. Проверки и фактические результаты

ОБЛАСТЬ	РЕЗУЛЬТАТ	ЧТО ПОДТВЕРЖДЕНО / ПРЕДЕЛ ПРОВЕРКИ
Фронт	**Пройдено**	TypeScript, production build, 109 тестов; 4 теста пропущены. Линтер: 0 ошибок и 3 существующих предупреждения. Контейнер запускается как `node`, UID 1000.
Go	**Пройдено**	`go mod verify`, `go vet ./...`, `go test -race -count=1 ./...` на Go 1.26.8. Некоторые пакеты не имеют отдельных unit-тестов и проверяются через интеграционные сценарии.
Заказы и производство	**Пройдено**	Три интеграционных сценария в новом временном Compose: standalone MVP, bootstrap лаборатории и SaaS. Проверены маршруты работ, статусы, назначения, завершения/KPI, аналитика, приём, согласования, качество, выдача/возврат, файлы, повторный пациент и разграничение доступа.
Фронт ↔ API	**Пройдено**	Браузерный smoke для 23 страниц демо, включая карточку заказа: нет ошибок JavaScript и неуспешных API-ответов. Проверены заказы, доски, справочники, сотрудники, пациенты, заметки, обучение, поддержка и сообщество. Это проверка загрузки страниц; все комбинации форм и ролей браузером не перебраны.
Аналитика	**Пройдено**	Согласованность итогов API, переход к заказу, четыре графика, переключение легенд, подсказки, мобильный экран и пустые данные. Отдельная аналитика производства сохранена; KPI сотрудников остаётся отдельным отчётом.
SaaS-границы	**Пройдено**	Проверены origin/CSRF, чужой host, закрытый worker, размер/поля JSON, cookie-изоляция, приватные обращения и файлы поддержки, ответы владельца, добровольное сообщество/модерация, MFA владельца, окончание тестового периода.
Восстановление	**Пройдено локально**	Полный холодный бэкап демо восстановлен в новые PostgreSQL/S3 volumes. База панели импортирована и проверена запросом. Работают readiness, вход, заказы и заметки. Файлы скопированы с проверкой manifest; отдельный контроль скачивания каждого восстановленного вложения не проводился.
Шифрование бэкапа	**Пройдено**	Реальный roundtrip `.ttbk`: шифрование отдельным тестовым ключом, аутентифицированная расшифровка, совпадение контрольных сумм. Unit-тесты проверяют повреждение архива и неверный ключ.
Параллельное чтение	**Пройдено в демо**	100 запросов заказов/аналитики, 5 параллельных читателей, 12 вымышленных заказов: 0 ошибок, p50 12,5 мс, p95 25,3 мс. Одна сессия на локальном компьютере — это не измерение производительности 3 рабочих лабораторий.
Скрипты и CI	**Пройдено**	13 Python-тестов для целостности бэкапов, политики аудита зависимостей и preflight. YAML workflow проверен actionlint 1.7.12; Compose проверен без вывода секретов. Сами workflows ещё не запускались на GitHub.

Сырые результаты находятся локально в `artifacts/production-audit/`. Резервные копии демо и тестовый ключ находятся в приватном runtime и не входят в архив продукта. Тестовые volumes CI и восстановления удалены; данные действующих лабораторий не удалялись.

2. Безопасность: исправления и открытые находки

Исправлено: минимум Go и Go build-образы закреплены на `1.26.8`, `klauspost/compress` обновлён до `1.18.7`. Конечный фронт работает без root, из него удалены npm/corepack/yarn. Добавлена ограниченная ротация Docker-логов в исходных Compose; существующие лаборатории получат её при контролируемом обновлении конфигурации.

Сканер Go не нашёл достижимых уязвимых вызовов в коде CRM. Отдельное предупреждение OpenPGP относится к модулю `x/crypto`: CRM использует bcrypt и не импортирует OpenPGP. Результат анализа вызовов нельзя распространять на старое хранилище или все сторонние бинарники. Методика Go vulnerability tools.

ОБРАЗ ПОСЛЕ ПРОВЕРКИ	HIGH / CRITICAL	РЕШЕНИЕ
Основной backend	0 / 0	Есть MEDIUM и UNKNOWN; их нужно отслеживать. Высоких/критических находок нет.
Фронт	0 / 0	Высокие находки в глобальном npm устранены удалением сборочных инструментов из runner. Остался 1 MEDIUM.
SaaS-панель	0 / 0	Есть UNKNOWN в метаданных Go-модуля. Сборка проверена; работа панели проверялась интеграционными тестами.
MinIO	39 / 6	**Блокер.** Закреплена старая версия 2025-10-15; есть находки в MinIO и его зависимостях, часть без исправления. Изоляция внутренней сети снижает поверхность атаки, но не заменяет поддерживаемое хранилище.
PostgreSQL 15, свежий образ	21 / 1	Находки относятся к Go stdlib в служебном `/usr/local/bin/gosu`, а не к Go-backend CRM и не автоматически к PostgreSQL. Нужен анализ используемых функций или проверенный образ с обновлённым helper. Сейчас CI блокирует выпуск.
nginx, свежий образ	2 / 0	libexpat и pcre2: сканер указывает исправленные версии. Подготовить исправленный gateway-образ, повторить health и browser smoke, закрепить digest. Сейчас CI блокирует выпуск.

Сканирование Trivy 0.75.0 с актуальной базой. PostgreSQL/nginx повторно проверены после pull, без замены работающих баз. Числа — записи предупреждений, а не количество доказанных атак. Совпадающие CVE могут затрагивать функции, которые в текущей конфигурации не используются.

Открытый репозиторий MinIO архивирован и сообщает об окончании поддержки. Для production нужен поддерживаемый S3-сервис или поддерживаемая установка с подходящими условиями лицензии. Обновлять множество зависимостей старого MinIO вслепую нельзя: требуется проверка совместимости и восстановления. При миграции сохрани bucket/object keys, сравни размер и SHA-256 каждого объекта, проверь обычные и multipart-вложения, затем восстановление и откат. Прямое копирование внутреннего каталога MinIO в другую S3-систему не является переносом объектов.

▼ **Временное исключение в инструментах разработки фронта**

`npm audit` полного дерева выдаёт 5 HIGH-предупреждений от одной уязвимости braces в цепочке линтера. Исправление отсутствует на дату проверки. Production-аудит npm не содержит уязвимостей. Исключение касается только dev-цепочки и заканчивается **6 ноября 2026**; новая находка, попадание в runtime или истечение срока блокируют CI. `npm audit fix --force` не использовался.

Подтверждены bcrypt, проверка ролей на сервере, ротация refresh-сессий, cookie-границы, лимиты запросов и отдельные базы/файлы лабораторий. Осталось: включить MFA владельца на сервере, проверить firewall/TLS, настроить мониторинг, разобрать CSP фронта с nonce для Next.js. MFA сотрудников, внешний pentest, DDoS-защита провайдера и антивирусная обработка всех вложений не реализованы этим аудитом.

3. Бэкапы, прекращение подписки и данные

Как сейчас устроены копии

`backup-all` сохраняет базу управления, каждую созданную лабораторию, её вложения/приватные настройки и образы для восстановления. В комплект входят и приостановленные лаборатории. Manifest проверяет наличие файлов и SHA-256; неполный комплект не отправляется как успешный.

Бэкап холодный: работающая лаборатория ненадолго останавливается. После копирования восстанавливается её прежнее состояние запуска. Лаборатории копируются последовательно; общей атомарной точки всех баз нет.

`.ttbk` защищён аутентифицированным шифрованием. Для внешнего комплекта предусмотрены age + rsync. Внешняя отправка сейчас **не настроена**. Обычные локальные копии сохраняются на диске и содержат секреты: нужны закрытые права и защита диска.

Что нужно на реальном сервере

- Отдельное внешнее хранилище с согласованным местом размещения и контролем доступа. Ключ расшифровки хранится отдельно от CRM и копий.
- Ежедневный таймер после смены; сигнал при ошибке отправки и отсутствии полного комплекта более 26 часов.
- Настроить срок хранения и очистку: автоматической retention-политики сейчас нет, локальные архивы и images могут заполнить диск.
- Каждый месяц восстановление в новый стенд; до первого клиента — восстановление внешней копии на чистом втором сервере.
- Предварительная цель: потеря данных не более 24 часов при успешном ежедневном бэкапе. Время восстановления измерить на реальном комплекте; обещать SLA до этого нельзя.

Если лаборатория отменяет подписку

Окончание trial или приостановка закрывает доступ через SaaS-портал; worker останавливает установку. Данные в базе и volumes не удаляются автоматически. Владелец может продлить период/возобновить доступ и сделать `export-data`: SQL, вложения и относящиеся к лаборатории данные платформы. Экспорт требует проверки получателя и защищённой передачи; сейчас нет автоматического клиентского кабинета выгрузки после блокировки.

1. До подключения клиента согласовать правила оплаты/остановки, срок получения экспорта, период хранения и удаления копий. Цифры 30/60/90 дней — бизнес-решение, в коде такого таймера сейчас нет.
2. Перед блокировкой предупредить контакт лаборатории и предложить экспорт. Продление и прекращение доступа пока управляются вручную, автоматического платёжного биллинга нет.
3. По подтверждённому запросу передать экспорт только уполномоченному представителю. Не отправлять клиенту серверный `.env`, ключи или чужие данные.
4. Удаление проводить отдельно по утверждённой политике: база, вложения, обращения, относящиеся персональные данные и последующее истечение срока резервных копий. Нельзя обещать мгновенное удаление из всех архивов, пока такой процесс не внедрён.

Этот отчёт не подтверждает юридическое соответствие обработки данных пациентов. До реальных данных нужны согласованные роли сторон, основание обработки, политика доступа/сроков, условия хранения и реагирование на инциденты. В общем сообществе и скриншотах поддержки нельзя публиковать данные пациентов.

4. Подготовленный CI и план CD

1 · Pull request

Типы, линтер, unit/race, API-интеграции, зависимости, сборки и сканирование образов.

2 · Кандидат

Выпуск только из main после CI. GHCR, уникальный тег, digest, отчёт сканера и SBOM.

3 · Тестовый стенд

Миграции, browser/E2E, роли, SaaS-изоляция и восстановление на вымышленных данных.

4 · Лаборатории

Preflight, бэкап, одна лаборатория, проверка. Затем остальные; остановка при ошибке.

Что уже добавлено в проект

ФАЙЛ	НАЗНАЧЕНИЕ
.github/workflows/ci.yml	PR/main/ручной запуск/еженедельная проверка. Фронт, Go race/vet/vulnerability scan, отдельные Postgres+S3 API-тесты и 6 проверяемых контейнеров. HIGH/CRITICAL блокируют образы.
.github/workflows/release.yml	Ручной выпуск из main после повторного CI, environment `release`, сборки Linux amd64, повторное сканирование именно выпускаемого образа, GHCR, digest/manifest и CycloneDX SBOM. Сервер не обновляет.
.github/dependabot.yml	Еженедельные PR для npm, Go, Docker и Actions; автоматического merge нет.
ci/compose.yaml, ci-integration.py	Случайное имя изолированного проекта, тестовые пароли, отсутствие production .env/volumes; в конце удаляются только временные ресурсы.
ci-security.py, audit-policy.json	Runtime/dev-аудит npm, контролируемое временное dev-исключение. Ошибка сервиса аудита не считается чистым результатом.
production-preflight.py	Только чтение: HTTPS/domain, приватные порты/конфиг/ключ, внешние копии и свежесть комплекта, HTTPS cookie, ротация логов. Не выводит значения секретов.
production-browser-check.cjs	Проверка 23 страниц локального презентационного демо без записи данных. Это локальный smoke, он пока не подключён как отдельный браузерный job CI.

Как активировать на GitHub

1. Поместить содержимое `teeth-tech-crm-mvp` в корень отдельного приватного репозитория. Сейчас рабочая папка не является Git-репозиторием. Если использовать общий monorepo, workflows надо перенести в его корневой `.github` и изменить пути.
2. Включить Actions/Dependabot и защиту main: PR, успешные обязательные checks, review, запрет force-push. Настроить environment `release` с доступом из main и одобрением выпуска, если это доступно в выбранном плане GitHub.
3. Не добавлять в Git `.env`, runtime, реальные дампы, ключи или файлы пациентов. Не копировать production-базу в GitHub CI. Настроить обнаружение секретов и обязательную проверку источников до первой публикации.
4. GitHub token используется только для GHCR в job публикации; остальные jobs имеют `contents: read`. Actions закреплены полными SHA. Это соответствует рекомендациям GitHub по безопасности workflows.
5. Добавить отдельный staging с вымышленными данными и браузерным E2E: приглашение → регистрация → bootstrap → заказ → этапы → качество → выдача → KPI, плюс поддержка, остановка/возобновление и отсутствие чужих данных.

На дату аудита публикация должна оставаться заблокированной. Image jobs для MinIO, PostgreSQL helper и nginx имеют открытые HIGH/CRITICAL. В workflows нет автоматического удаления баз, изменения подписок или SSH-деплоя.

Репозиторий GitHub, registry и сервер не подключены этим изменением.

5. Как безопасно выпускать обновления

1. Зафиксировать проверенный commit и digest всех образов. Backend/frontend выпускать совместимым комплектом. Текущий workflow создаёт Linux amd64 образы; для ARM-сервера нужна отдельная проверенная сборка.
2. На staging проверить новую и предыдущую версии на новой схеме. Миграции добавляют поля/таблицы без немедленного удаления старых; удаление — отдельный последующий релиз. Сейчас миграции запускаются при старте backend, отдельной версии схемы в deployment manifest нет.
3. В окно обслуживания запретить параллельное provision/update, приостановить worker, оставить owner-панель под контролем. Лабораторные блокировки защищают отдельные операции, но не весь многоэтапный релиз.
4. Создать и проверить полный backup-all и успешную внешнюю отправку. Выполнить preflight. Записать предыдущие image refs, конфиги и версию бинарника панели; иметь план восстановления.
5. Загрузить проверенные registry-образы по digest. Для приложения прописать refs в `SAAS_BACKEND_IMAGE` / `SAAS_FRONTEND_IMAGE` и использовать `update-application lab1`. Команда ожидает образы локально, сохраняет старые refs и проверяет health. Не заменять S3/Postgres этим способом.
6. Проверить вход, заказ/назначение/этап, аналитические итоги, заметки, скачивание файла и поддержку. Сверить отсутствие ошибок и рост latency. После согласованного периода наблюдения обновить lab2, затем lab3. При ошибке остановить rollout.
7. Панель Go и worker обновлять отдельно: сохранить старые executable/скрипты, проверить конфиг, перезапустить через systemd, проверить owner MFA, приглашения, proxy и истечение периода. Не считать `saasctl build` полноценным production rollout: он заменяет бинарник без полного release-протокола.

> **Откат контейнера не откатывает базу.** Существующая команда вернёт прежние образы/Compose при ошибке запуска, но миграция могла уже изменить данные. Восстанавливать старый SQL поверх базы после возобновления работы нельзя без остановки записей и согласования потери новых изменений. Для этого нужны совместимые миграции и отдельный план восстановления.

Пример проверок перед выпуском

```
python3 scripts/saasctl.py backup-all
python3 scripts/production-preflight.py
# После фиксации проверенных образов в настройках:
python3 scripts/saasctl.py update-application lab1
# Проверки карточки заказа, файлов, доступа и метрик; затем lab2/lab3.

# Отдельный стенд восстановления; пароль — через скрытый prompt:
python3 scripts/restore-check.py \
  --lab-backup /private/path/to/lab-backup \
  --images-backup /private/path/to/images-backup \
  --control-backup /private/path/to/control-backup \
  --email admin@example.kz
```

Preflight — проверка конфигурации. Даже его успешный код не подтверждает firewall, TLS, MFA в базе, возможность расшифровки внешней копии, отправку оповещений или юридические документы.

6. Что закрыть до реальных лабораторий

ПРИОРИТЕТ	ЗАДАЧА	КРИТЕРИЙ ЗАВЕРШЕНИЯ
P0 · Блокер	Поддерживаемое S3-хранилище и исправленные образы gateway/Postgres helper	Разобраны контейнерные HIGH/CRITICAL, исправления или обоснованная проверка достижимости; новые сканы, API/files/multipart и restore проходят. Не вводить общее исключение для всех CVE.
P0 · Блокер	HTTPS и изоляция на реальном Linux-сервере	DNS lab1/2/3, действительный сертификат/продление, Secure cookies, MFA владельца, снаружи доступны только необходимые HTTPS/SSH-порты; DB/S3/worker закрыты. SSH по ключу и ограниченный доступ администратора.
P0 · Блокер	Внешние копии и восстановление после потери сервера	Ежедневный полный комплект отправлен, ключ отдельно, восстановление на другом чистом сервере с входом/файлами и измеренным временем. Оповещение об ошибке проверено.
P0 · Блокер	Наблюдение и дисковая ёмкость	Оповещения о 5xx/readiness, завершении backup, заполнении диска, недоступности лаборатории и сертификате; ограниченная ротация Docker/systemd, retention бэкапов. Проверено получение тревоги владельцем.
P0 · До пациентов	Правила работы с данными и отменой подписки	Согласованы доступы, сроки, экспорт/удаление, хранение, ответственность и действия при инциденте; сотрудники обучены не публиковать пациентов в сообществе/поддержке.
P1 · До платного обещания SLA	Staging, browser E2E и rollback rehearsal	Сквозной жизненный цикл заказа, SaaS-приглашения/остановка/возобновление и обновление старой базы протестированы; предыдущая версия совместима или восстановление отрепетировано.
P1 · До роста	Реальная нагрузка и ресурсы	Проверены 3 активные лаборатории, несколько разных ролей/сессий, одновременные записи, большие STL-файлы, копирование и restart; измерены p95, память, диск и connection pools. Лимиты ресурсов назначены по результатам.
P1 · Масштабирование	Убрать ограничение трёх slots при расширении	Текущий SaaS намеренно рассчитан на lab1–lab3. Для четвёртой лаборатории нужны изменения слотов, маршрутизации, worker, копирования/экспорта и тестов; просто поднять мощность сервера недостаточно.
P2 · Следующий этап	Самостоятельный экспорт, биллинг, расширенная защита	Кабинет продления/отмены, read-only/grace-период по договору, понятный экспорт JSON/CSV, процедура удаления, MFA сотрудников/CSP/обработка вредоносных вложений; разработка после базовых блокеров.

Следующий практический шаг — закрыть хранилище и контейнерные находки, затем собрать тестовый Linux-стенд с HTTPS и внешними копиями. После этих проверок можно открыть ограниченный пилот с реальными данными на согласованных условиях. Покупка сервера сама по себе не устраняет обнаруженные блокеры.

Отчёт описывает локальную сборку на дату аудита. После изменения зависимостей, схемы или инфраструктуры соответствующие проверки следует повторить. Функциональная готовность, безопасность образов и настройка сервера оцениваются отдельно.